Vulnerability Assessment Report

Rayane Merlin

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Part to complete :

Purpose

Consider the following questions to help you write:

- *How is the database server valuable to the business?*
- *Why is it important for the business to secure the data on the server?*
- *How might the server impact the business if it were disabled?*

The database server is essential because employees query it every day to find customers. Since it has been open to the public, anyone can reach the stored data. Securing it protects the confidentiality and integrity of that data, and as a result the trust of the customers. If the server is disabled, all remote employees could not work. This may be causing operational, financial, and reputational damage.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Competitor	*Obtain sensitive information via exfiltration*	*1*	*3*	*3*

Cybercriminal	*Sensitive data exfiltration from the public database*	*3*	*3*	*9*
Insider (malicious employee)	*Unauthorized alteration of data*	*2*	*2*	*4*

Approach

They are the most realistic ways an openly exposed database could be compromised: an outside attacker, a competitor, and a malicious employee.

Each event targets a different security principle: confidentiality, availability, and integrity. The server is reachable from the internet so an attack is very likely.

Remediation Strategy

- Placing the server behind a firewall and VPN, so only authorized employees can connect
- Apply the principle of least privilege
- Require MFA for every login, and use the AAA framework to authenticate users, authorize their actions, and log all activity for future audits
- Encrypt data in transit and at rest